Relatório de segurança dos dados

Revenda de veículos · Tech Challenge SOAT · Fase 5 · 05/11/2026

> Esta entrega descreve código e infraestrutura declarada. `infra/config/dev.yml` contém `destroy: true`: não há implantação ativa. Testes locais não comprovam latência, custos, achados de segurança ou comportamento E2E na AWS.

1. Inventário dos dados

Dados / localização	Natureza e proteção
Catálogo (DynamoDB veículos)	Marca, modelo, ano, cor, preço e disponibilidade; listagem pública dos disponíveis. Placa, chassi e RENAVAM e a gestão ficam restritos a funcionários.
Perfil (DynamoDB clientes)	Nome, e-mail, telefone e endereço: sem cifragem por campo; protegidos por IAM, autorização e criptografia em repouso. Não devem aparecer em logs.
CPF / RG / CNH	Cifra por campo (sealed box X25519/libsodium). CPF tem também HMAC para unicidade; e-mail e IP de consentimento têm HMAC nos usos previstos. CNH opcional; cadastro completo exigido na compra.
Vendas e pagamentos	IDs vinculáveis ao titular, snapshot do veículo, valor, estados, histórico, código Pix e referências do gateway. Nenhum cartão.
Consentimentos e solicitações	Versões e finalidades, datas, IP protegido por HMAC e registro das solicitações LGPD.
Credenciais e chaves	Senhas gerenciadas pelo Cognito. Tokens no sessionStorage do navegador. Segredos e chave privada no SSM SecureString (KMS gerenciado pela AWS).
Auditoria e telemetria	Eventos com IDs, ator, operação e finalidade (potencialmente pessoais por vínculo). Logs de aplicação: 7 dias; auditoria: 1827 dias.

CPF, RG e CNH são tratados como dados pessoais de alto risco de fraude. A qualificação jurídica e as bases legais devem ser validadas antes de uso real.

2. Políticas de acesso

O API Gateway valida o Cognito nas rotas protegidas. Os handlers verificam token de acesso, client ID, emissor, papel e dono do recurso. Admin herda vendedor; clientes não acessam vendas de terceiros. Testes exercitam a matriz de rotas × perfis e cenários de IDOR.

Uma role IAM por Lambda e uma permissions boundary limitam o acesso. Em runtime, só clientes-interno e lgpd-worker leem a chave privada PII. Respostas comuns mascaram documentos; a função interna decifra para cobrança, documentação autorizada e exportação do titular.

3. Tratamento e retenção

Consentimentos versionados no cadastro. Exportação do titular autenticada, limitada a uma por 24 h. Exclusão recusada durante compra em andamento; fora disso, anonimiza o perfil e remove o login Cognito. Com vendas concluídas, preserva registro mínimo (nome, CPF cifrado e IDs de vendas) em

RETENCAO_LEGAL com TTL de cerca de cinco anos. É política do exercício, não validação do prazo legal. Rotina diária (06:00 UTC) anonimiza inativos há 730 dias, sem histórico de venda.

4. Segurança operacional

MFA obrigatório para funcionários, autorização de negócio, TLS, cabeçalhos de segurança, sanitização de logs. Webhook com HMAC, timestamp, validação de valor e idempotência; rotas internas do gateway simulado usam SigV4.

Primeiro administrador. Nenhuma conta administrativa é criada por script. A rota pública `POST /configuracao-inicial` só funciona enquanto o grupo admin está vazio e só convida o e-mail declarado na implantação; a senha temporária vai só à caixa do dono. Responde 409 depois do primeiro, tem limite de taxa e é auditada.

Terraform e GitHub Actions/OIDC permitem revisão e credenciais temporárias. O CI executa SAST (bandit), auditoria de dependências, análise de workflows e detecção de segredos (gitleaks). Isso não prova ausência de vulnerabilidades. Em incidente: identificar e conter, preservar evidências, corrigir a causa, avaliar obrigações com os responsáveis e verificar a recuperação.

5. Riscos e mitigação

Risco	Mitigação implementada	Limite residual
Exfiltração de clientes	Cifra CPF/RG/CNH, IAM/boundary, controles de dono e papel	Nome, contato e endereço legíveis a principais autorizados; comprometer a função interna expõe dados
Reserva ou retirada concorrente	Transações, condições e lock; desistência persistida antes do callback	Sem transação ACID global; falhas entre serviços exigem compensação
Webhook falso ou repetido	HMAC, timestamp, validação de valor, idempotência	Segredo comprometido permite falsificação
Callback perdido	Reentrega e reconciliação no timeout	Falha definitiva pode exigir redrive administrativo
Perda de dados	Estrutura e seeds reproduzíveis por IaC e migrações	Sem PITR (custo): vendas reais não são recuperáveis; definir backup antes de produção
Abuso / XSS / credenciais	Throttling, validação, CSP, MFA, revogação de sessão	Sem WAF (custo); sessionStorage não protege contra XSS na origem
Criação indevida do primeiro administrador	Rota só convida o e-mail declarado na implantação; fecha após o primeiro; limite de taxa e auditoria	Quem controlar a caixa de e-mail do dono assume a administração
Observabilidade insuficiente	Logs, auditoria, métricas e 9 alarmes	Sem GuardDuty/Security Hub (custo): sem detecção gerenciada de ameaças
Retenção excessiva	Anonimização, TTL do registro mínimo, rotina de inativos	Cobertura parcial por categoria; exige revisão de base legal

6. Controles de segurança não implementados (apenas documentados)

Os controles abaixo **não estão implementados** no código nem no Terraform: foram deixados de fora por custo, pois o projeto é acadêmico e roda em conta pessoal. Estão apenas documentados como evolução para produção. Os valores variam por região e mudam com o tempo; confirme nas páginas de preço da AWS.

Controle	O que protegeria	Justificativa de custo	Mitigação atual
AWS WAF	Bloqueio de ataques web na borda	Mensalidade fixa por Web ACL e por regra, mais cobrança por requisição; sem cota gratuita	Throttling no API Gateway, validação de entrada, Cognito, cabeçalhos de segurança
Amazon GuardDuty	Detecção gerenciada de ameaças na conta	Gratuito só durante a avaliação; depois cobra por volume de eventos analisados	Alarmes CloudWatch e auditoria de aplicação
AWS Security Hub	Consolidação de achados e padrões (CIS, FSBP)	Gratuito só na avaliação; depois cobra por verificação e achado, e depende do AWS Config	Revisão de IaC, bandit, pip-audit, gitleaks e zizmor no CI
Amazon Macie	Descoberta de dados sensíveis em S3	Cobra por bucket e por dado inspecionado; dados pessoais não ficam em S3 (só o site estático)	Dados pessoais no DynamoDB, com CPF/RG/CNH cifrados por campo
Chave KMS gerenciada pelo cliente	Política, rotação e auditoria próprias da chave	Mensalidade por chave e cobrança por uso; os segredos usam `alias/aws/ssm` (chave gerenciada pela AWS)	Cifra por campo (libsodium) com chave privada em SSM SecureString, lida só por duas funções
DynamoDB PITR	Restauração a um ponto no tempo	Cobrado por GB-mês de backup contínuo, fora do free tier	Tabelas e dados iniciais recriáveis por Terraform e migrações; vendas reais não são recuperáveis
CloudTrail próprio	Auditoria permanente das chamadas à API AWS	Trail adicional exige armazenamento em S3 e, para eventos de dados, cobrança por evento	Histórico padrão da conta (90 dias) e auditoria de aplicação (SNS → SQS → CloudWatch Logs)

7. Evidências e limites

Testes automatizados de autorização, criptografia, privacidade, SAGA e contratos rodam localmente (555 testes do backend, cobertura de 95%). Não houve varredura de logs implantados, auditoria jurídica ou avaliação de achados na conta AWS.